FACULTAD DE INGENIERIA
Universidad de Buenos Aires

ISO/IEC 27001:2022:

La seguridad de la información ha trascendido su concepción tradicional como una disciplina estrictamente técnica para consolidarse como un imperativo fundamental de la gobernanza corporativa, la gestión de riesgos sistémicos y la resiliencia operativa. En un ecosistema empresarial caracterizado por la interconexión global, la proliferación de infraestructuras en la nube y un panorama de amenazas cibernéticas cada vez más sofisticado, la protección de los activos de información determina la viabilidad a largo plazo de cualquier organización. En este contexto, la norma ISO/IEC 27001, desarrollada por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC), se erige como el estándar internacional preeminente para el diseño, la implementación, el mantenimiento y la mejora continua de un Sistema de Gestión de Seguridad de la Información (SGSI).[1]

La promulgación de la actualización ISO/IEC 27001:2022 introdujo transformaciones estructurales y filosóficas profundas en comparación con su predecesora del año 2013.[3] Estos cambios fueron diseñados explícitamente para alinear los controles de mitigación con la evolución de las amenazas digitales modernas, reflejando el entendimiento de que la ciberseguridad es una responsabilidad organizativa integral que abarca personas, procesos físicos y tecnológicos.[4] El presente informe de investigación desglosa de manera exhaustiva la anatomía de la norma ISO/IEC 27001:2022, prestando especial atención a las metodologías de implementación estratégica, las listas de verificación (checklists) sugeridas para las auditorías internas y externas, y la transición hacia la automatización del cumplimiento. Asimismo, se explora el ecosistema regulatorio específico de la República Argentina, analizando el impacto de las normativas del Banco Central (BCRA) y las estrategias de adopción en el sector financiero y las Pequeñas y Medianas Empresas (PyMEs).

Fundamentos del Sistema de Gestión de Seguridad de la Información (SGSI)

El propósito central e innegociable de la norma ISO/IEC 27001 es proporcionar un marco estructurado para mitigar los riesgos asociados a la información, garantizando la preservación de tres principios fundamentales conocidos en la industria como la tríada CIA: Confidencialidad, Integridad y Disponibilidad.[2] El análisis de estos pilares revela que la confidencialidad asegura que los datos sensibles sean accesibles única y exclusivamente por las entidades o individuos autorizados, requiriendo mecanismos como el cifrado y la gestión estricta de identidades.[2] La integridad garantiza que la información se mantenga inalterada, precisa y completa a lo largo de todo su ciclo de vida, previniendo modificaciones indebidas o maliciosas.[2] Finalmente, la disponibilidad certifica que los sistemas críticos y los datos subyacentes estén accesibles y operativos para los usuarios legítimos en el momento exacto en que se requieran, exigiendo planes de continuidad y redundancia tecnológica.[2]

A diferencia de otros marcos de ciberseguridad que actúan como meras guías de mejores prácticas o recomendaciones voluntarias, ISO 27001 es un estándar formalmente certificable.[2] La implicancia directa de esta característica es que una organización no solo debe implementar un conjunto disperso de controles de seguridad, sino que debe demostrar empíricamente ante un auditor externo e independiente que su SGSI funciona de manera eficaz, sistemática y bajo una filosofía irrenunciable de mejora continua.[2] Es imperativo comprender que la obtención del certificado no depende de la mera presencia técnica de software de seguridad, sino de la existencia de un sistema de gestión maduro que racionaliza, selecciona y documenta dichos controles basándose en las necesidades operativas reales y en un análisis de riesgos exhaustivo y particularizado para la organización.[6]

Arquitectura Normativa: Cláusulas Obligatorias (4 a 10)

La arquitectura de la norma se divide orgánicamente en dos bloques principales y

complementarios: las cláusulas obligatorias (numeradas del 4 al 10), que dictan los requisitos ineludibles del sistema de gestión, y el Anexo A, que proporciona un catálogo discrecional de controles de seguridad de referencia.[7] Para lograr y mantener la certificación, el cumplimiento estricto de todas las cláusulas de la 4 a la 10 es un requisito absoluto, constituyendo el esqueleto administrativo del estándar.[8]

La Cláusula 4 exige una inmersión analítica para comprender el contexto interno y externo de la organización. Esto implica identificar a todas las partes interesadas relevantes (clientes, entes reguladores, accionistas, proveedores críticos) y definir de manera inequívoca el alcance del SGSI.[7] El alcance determina los límites físicos, lógicos y organizacionales del sistema. Una delimitación errónea puede desencadenar consecuencias catastróficas: un alcance demasiado amplio diluye los recursos y encarece la implementación, mientras que un alcance demasiado restrictivo genera falsas sensaciones de seguridad al dejar sistemas críticos expuestos y fuera de la auditoría.

La Cláusula 5 aborda el Liderazgo, un componente que determina la viabilidad política y financiera del proyecto. La alta dirección debe demostrar un compromiso tangible y documentado, redactando, aprobando y comunicando una Política de Seguridad de la Información coherente con la estrategia del negocio.[4] Además, deben asignarse explícitamente los roles, las responsabilidades y los presupuestos necesarios.[7] Sin el patrocinio ejecutivo continuo, cualquier SGSI está destinado al fracaso burocrático, ya que los controles técnicos carecerán de la autoridad institucional necesaria para alterar la cultura de la empresa.

La Cláusula 6 constituye el núcleo estratégico y táctico del estándar: la Planificación. En esta etapa se exige el diseño y la adopción de una metodología de evaluación de riesgos que sea rigurosa, documentada y repetible a lo largo del tiempo.[7] Las organizaciones deben identificar metódicamente las amenazas, evaluar su impacto potencial y su probabilidad de ocurrencia, y decidir formalmente cómo tratarlas. Las opciones de tratamiento incluyen evitar el riesgo, mitigarlo mediante la aplicación de controles, transferirlo (por ejemplo, a través de pólizas de seguro cibernético o tercerización) o aceptarlo conscientemente bajo la firma de la dirección.[7] Como resultado directo de este proceso, se genera la Declaración de Aplicabilidad (SoA,

Statement of Applicability), un documento maestro que vincula los riesgos identificados con los controles específicos del Anexo A que la organización ha decidido implementar para mitigarlos.[3]

Las Cláusulas 7 (Soporte) y 8 (Operación) se centran en la ejecución material de las directrices planificadas. Esto abarca la provisión continua de recursos, la evaluación de la competencia del personal, la ejecución de programas de concientización sobre amenazas cibernéticas, la gestión rigurosa de la información documentada (control de versiones, almacenamiento, retención) y la ejecución efectiva del plan de tratamiento de riesgos en las operaciones diarias.[7]

La Cláusula 9 (Evaluación del Desempeño) requiere el monitoreo continuo de las métricas de seguridad, la realización de auditorías internas periódicas y las revisiones directivas (Management Reviews).[9] Finalmente, la Cláusula 10 (Mejora Continua) exige el establecimiento de un proceso estructurado para reaccionar ante las no conformidades, investigar las causas raíz de las brechas de seguridad y aplicar acciones correctivas que eviten la recurrencia de las fallas.[9] Este enfoque circular se alinea profundamente con el ciclo de Deming: Planificar, Hacer, Verificar y Actuar (PDCA), promoviendo un ecosistema de cumplimiento dinámico.[14]

La Reestructuración Estratégica del Anexo A: De 2013 a 2022

El cambio más paradigmático y visible de la versión 2022 reside en la reingeniería total del Anexo A. Históricamente, la versión 2013 agrupaba 114 controles fragmentados en 14 dominios distintos.[3] Esta taxonomía a menudo generaba redundancias operativas, confusión conceptual y dificultaba la asignación clara de responsabilidades interdepartamentales. En respuesta a estas ineficiencias, la versión 2022 condensa este catálogo en 93 controles organizados lógicamente en 4 grandes ejes temáticos.[3] El proceso de consolidación eliminó redundancias fusionando 24 controles (provenientes de dos o más controles anteriores), revisó y

renombró 58 controles para alinearlos con la terminología tecnológica contemporánea, y eliminó controles que habían quedado obsoletos.[3]

Esta reestructuración temática (Organizacionales, Personas, Físicos y Tecnológicos) trasciende la mera conveniencia cosmética; representa una evolución en cómo las organizaciones deben concebir la postura de defensa. Refleja el consenso de la industria de que la ciberseguridad es una responsabilidad sinérgica y compartida, no una carga aislada exclusivamente en el departamento de Tecnología de la Información (TI).[4]

El primer eje, compuesto por los Controles Organizacionales, concentra 37 controles que representan la columna vertebral administrativa y de gobernanza del SGSI.[4] Estos controles (numerados del A.5.1 al A.5.37) establecen que la seguridad debe gestionarse desde una perspectiva directiva.[4] Abarcan directrices como la gestión de políticas, la segregación de funciones (vital para prevenir el fraude y el error humano al asegurar que ninguna persona tenga control total sobre un proceso crítico, dividiendo la ejecución, la autorización y la verificación), y el contacto predefinido con autoridades y grupos de interés.[4] Un análisis de este eje revela que la gestión de seguridad en las relaciones con los proveedores (A.5.19 a A.5.22) ha cobrado un protagonismo absoluto debido a la escalada global de ataques dirigidos a la cadena de suministro (supply chain attacks), obligando a las empresas a evaluar, auditar y monitorear continuamente las posturas de ciberseguridad de sus socios comerciales y contratistas de la nube.[12]

El segundo eje, los Controles de Personas, agrupa 8 directrices enfocadas en gestionar el riesgo asociado al factor humano, tradicionalmente considerado el eslabón más vulnerable de cualquier arquitectura de seguridad.[4] Estos controles abarcan todo el ciclo de vida del empleado: desde la selección inicial y el escrutinio riguroso de antecedentes (background checks) antes de la contratación formal, hasta la firma de acuerdos de confidencialidad, la imposición de procesos disciplinarios por negligencia, la concientización ininterrumpida sobre ingeniería social, y los protocolos seguros para la desvinculación o finalización de contratos.[12] El análisis de estos controles sugiere una fuerte tendencia del estándar hacia la construcción de una "cultura de seguridad" corporativa, donde el entrenamiento no es un evento anual

aislado, sino una métrica de desempeño operativo.[15]

El tercer eje, integrado por 14 Controles Físicos, está diseñado para proteger el perímetro tangible, las instalaciones, las oficinas y el hardware corporativo contra accesos no autorizados, daños e interferencias.[4] Las medidas van desde el diseño arquitectónico de áreas seguras, la implementación de controles de acceso físicos (biometría, tarjetas magnéticas), la protección contra amenazas ambientales (incendios, inundaciones), hasta la imposición de políticas estrictas de escritorios limpios y pantallas bloqueadas.[4] A pesar de la migración masiva hacia el paradigma del trabajo en la nube, el control físico mantiene su criticidad insoslayable para proteger infraestructuras críticas, routers, servidores locales y dispositivos terminales móviles contra robos o manipulaciones directas.

Finalmente, el cuarto eje consolida 34 Controles Tecnológicos, englobando las implementaciones técnicas preventivas, detectivas y correctivas utilizadas para asegurar los sistemas lógicos y los flujos de datos.[4] Este dominio incluye la gestión robusta de vulnerabilidades, el diseño de arquitecturas de red seguras, la aplicación de criptografía fuerte, y la separación estricta y demostrable entre los entornos de desarrollo, prueba y producción para evitar fugas de datos operativos.[4]

El Impacto de los 11 Nuevos Controles frente a las Amenazas Emergentes

Para dimensionar verdaderamente la profundidad de la versión 2022, resulta indispensable analizar los 11 controles técnicos y organizacionales introducidos por primera vez.[3] Estos controles actúan como un barómetro preciso de las ansiedades actuales de la industria tecnológica y delinean el estándar de diligencia debida esperado para los próximos años [9]:

1. **Inteligencia de Amenazas (Threat Intelligence - A.5.7):** Este control organizacional exige la recopilación proactiva, el análisis y la distribución de información sobre vectores de ataque emergentes y tácticas de actores maliciosos. El objetivo es permitir que la organización anticipe ataques mediante

decisiones estratégicas basadas en el riesgo, en lugar de reaccionar pasivamente.[4]

2. **Seguridad de la Información en el Uso de Servicios en la Nube (A.5.23):** Busca regular y documentar el modelo de responsabilidad compartida entre el proveedor de servicios en la nube (CSP) y el cliente. Históricamente, la incomprensión de este límite ha generado fugas masivas de datos debido a contenedores o bases de datos mal configuradas.[4]
3. **Preparación de las TIC para la Continuidad del Negocio (A.5.30):** Enfocado puramente en la resiliencia operativa. Exige que las tecnologías de la información y la comunicación estén preparadas para soportar operaciones mínimas y recuperarse rápidamente ante desastres disruptivos, mitigando el impacto de ataques destructivos como el ransomware.[9]
4. **Monitoreo de Seguridad Física (A.7.4):** Implica la vigilancia activa y continua (por ejemplo, a través de sistemas CCTV avanzados, sensores de movimiento y alarmas conectadas a centros de monitoreo) para disuadir y detectar intrusiones físicas no autorizadas en áreas críticas.[9]
5. **Gestión de la Configuración (A.8.9):** Demanda la estandarización segura (hardening) de las configuraciones de hardware, software y redes, previniendo vulnerabilidades derivadas de configuraciones predeterminadas de fábrica o cambios no autorizados.[9]
6. **Eliminación de Información (A.8.10):** Establece protocolos estrictos para el borrado seguro, irrecuperable y definitivo de datos cuando estos ya no son necesarios para los fines comerciales. Este control está profundamente alineado con las regulaciones globales de privacidad y el derecho al olvido.[9]
7. **Enmascaramiento de Datos (Data Masking - A.8.11):** Vital para proteger la Información de Identificación Personal (PII) u otros datos sensibles durante las fases de prueba de software o entrenamiento de sistemas. Obliga a reemplazar los datos reales con información ofuscada, seudonimizada o sintética.[9]

8. **Prevención de Fuga de Datos (Data Leakage Prevention / DLP - A.8.12):** Requiere la implementación de políticas y herramientas de software diseñadas para monitorizar, detectar y bloquear proactivamente la extracción no autorizada de información confidencial hacia el exterior (por ejemplo, a través de correos electrónicos no encriptados, dispositivos USB o cargas a almacenamientos en la nube personales).[4]
9. **Monitoreo de Actividades (A.8.16):** Obliga a las organizaciones a desplegar sistemas de detección (tales como SIEM o EDR) para monitorizar redes, sistemas de TI y aplicaciones, identificando anomalías, comportamientos inusuales de usuarios y eventos anómalos en tiempo real, vinculándolos con procedimientos de respuesta a incidentes.[5]
10. **Filtrado Web (A.8.23):** Exige la implementación de restricciones técnicas para gestionar y limitar los sitios web a los que el personal puede acceder desde las redes corporativas, minimizando drásticamente la superficie de exposición a malware, descargas no autorizadas (drive-by downloads) y dominios de phishing.[5]
11. **Codificación Segura (Secure Coding - A.8.28):** Institucionaliza la integración de principios de seguridad desde las fases iniciales del ciclo de vida del desarrollo de software (DevSecOps). Su objetivo es erradicar vulnerabilidades estructurales en el código fuente antes de que el software sea desplegado en entornos de producción.[5]

Diferenciación Crítica: Análisis de Brechas vs. Evaluación de Riesgos

En el trayecto hacia la implementación del estándar, es excepcionalmente común que las organizaciones, e incluso ciertos consultores, confundan operativamente el Análisis de Brechas (Gap Analysis) con la Evaluación de Riesgos (Risk Assessment). Una implementación técnica exhaustiva requiere comprender que estos procesos son

metodológicamente distintos, aunque sus resultados sean complementarios para el éxito del SGSI.[8]

El **Análisis de Brechas (Gap Analysis)** es una evaluación de diagnóstico del estado actual de la organización comparado directamente con los requisitos teóricos y prescriptivos de la norma ISO 27001.[8] Este ejercicio se enfoca en determinar la distancia entre lo que la empresa hace hoy y lo que el estándar exige que haga en el futuro. Generalmente se utilizan herramientas de evaluación, plantillas (como sistemas de Evaluación de Madurez o FOSS Tools con cuadros de mando) y listas de verificación exhaustivas para identificar qué cláusulas (del 4 al 10) y qué controles del Anexo A están parcial o totalmente ausentes en la estructura organizativa.[11] Por ejemplo, si el requerimiento de la cláusula 9.2 indica que deben realizarse auditorías internas planificadas, y la empresa carece de un programa documentado al respecto, el Análisis de Brechas identifica esto como una deficiencia formal que debe ser rectificada.[8] El resultado primordial de este análisis es una hoja de ruta operativa que detalla las acciones correctivas inmediatas, las políticas faltantes y las inversiones necesarias para alinear la infraestructura y los procesos con el estándar.[11]

Por el contrario, la **Evaluación de Riesgos (Risk Assessment)**, exigida por la cláusula 6.1.2 de la norma, es un proceso metodológico y analítico destinado a identificar los activos de información críticos, descubrir las amenazas específicas que pesan sobre ellos (por ejemplo, ataques de ransomware, fallas de suministro eléctrico, robo interno de bases de datos), identificar las vulnerabilidades inherentes que permitirían que la amenaza se materialice, y calcular matemáticamente o cualitativamente el nivel de riesgo en función del impacto en el negocio y la probabilidad de ocurrencia.[7] Mientras que el Gap Analysis hace una pregunta de cumplimiento ("¿Cumplimos con este párrafo específico de la norma ISO?"), la Evaluación de Riesgos hace una pregunta de supervivencia ("¿Qué impacto financiero y reputacional sufriríamos si nuestra base de datos principal fuera secuestrada o destruida mañana?").

La relación simbiótica entre ambos procesos radica en que los resultados de la Evaluación de Riesgos determinan exactamente qué controles del Anexo A deben seleccionarse, justificarse e implementarse a través del Plan de Tratamiento de

Riesgos, los cuales a su vez cerrarán las brechas sistémicas identificadas en el Gap Analysis inicial.[7]

Metodología de Implementación: Hoja de Ruta Estratégica

La implementación de la norma ISO 27001 no debe abordarse como un proyecto de instalación de tecnología, sino como un programa de transformación de la cultura corporativa y gestión del cambio organizacional.[15] Un análisis de las mejores prácticas globales indica que el proceso de implementación y certificación se estructura generalmente en una hoja de ruta que abarca múltiples pasos interconectados, exigiendo la asignación de recursos, tiempos y presupuesto.[7]

Costos e Inversiones Involucradas

La decisión de implementar el estándar conlleva implicancias financieras significativas que deben ser aprobadas por la alta dirección. La estructura de costos típicos involucra cinco pilares: el costo de la literatura oficial y la capacitación formal del personal; el costo de la asistencia externa (consultores expertos en GRC); el costo del tiempo de los empleados internos dedicados a diseñar procesos y redactar políticas; el costo de las nuevas tecnologías o licencias de seguridad requeridas para mitigar los riesgos identificados; y finalmente, las tarifas abonadas al organismo de certificación externo para las auditorías de Fase 1 y Fase 2.[19]

El Proceso Secuencial de Implementación

Para asegurar el éxito, la implementación sigue un ciclo estructurado:

1. **Comprensión Estructural y Apoyo Directivo:** Iniciar obteniendo el compromiso inquebrantable de la alta gerencia y comprendiendo la estructura detallada de las cláusulas 4 a 10 y el Anexo A de la versión 2022.[7]
2. **Conformación del Equipo de Implementación:** Designar un Líder de Proyecto con conocimientos comprobados en seguridad de la información. Este

equipo debe ser multidisciplinario, incorporando representantes de TI, Recursos Humanos, Legales, Operaciones y Finanzas, garantizando que el SGSI refleje las realidades de toda la organización.[7]

3. **Definición del Alcance del SGSI (Cláusula 4.3):** Documentar formalmente qué activos, procesos, sedes físicas y unidades organizativas estarán protegidos por el sistema y sometidos a auditoría.[7]
4. **Ejecución del Análisis de Brechas (Gap Analysis):** Evaluar los sistemas y políticas preexistentes frente a los requisitos de ISO 27001 para priorizar las recomendaciones y dimensionar el esfuerzo de implementación (típicamente estimado en 2 semanas de trabajo de diagnóstico).[7]
5. **Creación de la Política de Seguridad de la Información (ISP):** Redactar el documento fundacional (Cláusula 5.2) que establece las reglas de alto nivel, el propósito, los objetivos y el compromiso directivo.[7]
6. **Definición de la Metodología de Evaluación de Riesgos:** Establecer formalmente si se utilizará un enfoque cualitativo o cuantitativo, definiendo los criterios de apetito de riesgo y las escalas de impacto y probabilidad.[7]
7. **Ejecución de la Evaluación y el Tratamiento de Riesgos:** Inventariar los activos, identificar amenazas, calcular los riesgos y diseñar el Plan de Tratamiento de Riesgos (RTP). En esta fase se seleccionan los controles del Anexo A necesarios para mitigar los riesgos inaceptables.[7]
8. **Elaboración de la Declaración de Aplicabilidad (SoA):** Este es el documento más crítico para el auditor. Debe contener una matriz con los 93 controles del Anexo A, indicando para cada uno si ha sido seleccionado para implementación o excluido, la justificación detallada de dicha decisión (por ejemplo, mitigación de un riesgo particular o cumplimiento de una ley), y el estado actual de implementación del control.[3]
9. **Desarrollo de Documentación y Procedimientos:** Redactar y aprobar el extenso cuerpo documental exigido, asegurando el control de versiones, la comunicación a las partes relevantes y el establecimiento de protocolos de

retención.[7]

10. **Implementación de la Estrategia de Controles y Operación:** Desplegar técnica y operativamente las medidas de seguridad tecnológicas, físicas y organizacionales en toda la empresa.[7]
11. **Programas de Concientización de Empleados:** Iniciar ciclos continuos de capacitación, integrando la seguridad en el proceso de inducción de nuevos empleados (onboarding) y estableciendo procesos disciplinarios para el incumplimiento.[7]
12. **Auditoría Interna:** Previo a la certificación formal, ejecutar una revisión profunda de todas las cláusulas y controles aplicables utilizando auditores internos imparciales para identificar no conformidades tempranas.[7]
13. **Revisión por la Dirección (Management Review):** Someter los resultados de la auditoría interna, las métricas del SGSI y el estado de los riesgos a la revisión formal de la alta gerencia.[7]
14. **Acciones Correctivas:** Implementar planes de remediación para cualquier desviación o no conformidad identificada durante la auditoría interna.[7]
15. **Auditoría de Certificación Externa:** Someterse a la evaluación del organismo certificador acreditado. Este proceso consta de la Fase 1 (revisión exhaustiva de la documentación y el diseño del SGSI) y la Fase 2 (auditoría presencial o in situ para verificar que los controles operan eficazmente en la práctica).[8]
16. **Mantenimiento y Mejora Continua:** Tras la certificación, establecer ciclos de auditorías de vigilancia periódicas para garantizar que el SGSI evoluciona y se adapta a las nuevas dinámicas empresariales y amenazas cibernéticas.[7]

Diseño y Aplicación de Listas de Verificación (Checklists) para Auditoría

Las listas de verificación (checklists) representan herramientas operativas y tácticas

indispensables para estructurar, estandarizar y registrar las evidencias durante los procesos de implementación y las auditorías internas. Facilitan la recolección de datos, apoyan los informes de indicadores clave de rendimiento (KPIs) y documentan la revisión por la dirección.[22]

No obstante, los consultores expertos en ISO 27001 emiten una advertencia crítica sobre la falacia del "Un-Checklist".[6] El cumplimiento de una lista de verificación de autoevaluación, completando mecánicamente el 80% de las casillas con un "Sí", a menudo proporciona información no concluyente y peligrosamente engañosa sobre la preparación real para la certificación.[6] Un auditor competente no verifica la mera existencia estática de un control técnico o la redacción de un documento en papel; evalúa la vitalidad, la comprensión interdepartamental y la aplicación sistemática de los procesos dentro de un sistema de gestión integrado que racionaliza esos controles.[6] Las listas de verificación deben concebirse como disparadores estructurados para la indagación y el análisis profundo de evidencias objetivas, soportando metodologías de aseguramiento de resultados.[14]

La evaluación de auditoría interna de la versión 2022 se estructura típicamente en dos dimensiones de cuestionamiento masivo, totalizando aproximadamente 246 preguntas críticas [9]: el marco maestro de cumplimiento del SGSI y la verificación de controles discrecionales.

Matriz 1: Lista de Verificación de Documentación Obligatoria

El sustento probatorio del SGSI reside en la información documentada. La ausencia de los siguientes artefactos constituye, por sí misma, una no conformidad mayor durante una auditoría.[10]

Referencia Normativa	**Requisito Documental Exigido por el Estándar**	**Criterio de Verificación de Calidad y Cumplimiento**

Cláusula 4.3	Alcance del Sistema de Gestión de Seguridad de la Información (SGSI)	El documento define claramente los límites del sistema, interfaces tecnológicas e instalaciones. Ha sido firmado por la dirección.
Cláusula 5.2	Política General de Seguridad de la Información	La política está alineada con los objetivos del negocio, refleja el compromiso de mejora continua y ha sido comunicada a todo el personal.
Cláusula 6.1.2	Proceso de Evaluación y Tratamiento de Riesgos	Existe un manual detallado que especifica los criterios matemáticos o cualitativos para evaluar el impacto y la probabilidad de las amenazas.
Cláusula 6.1.3	Declaración de Aplicabilidad (SoA)	Documento matriz que lista los 93 controles del Anexo A, justificando todas las inclusiones y exclusiones bajo criterios de riesgo y detallando su estado de implementación actual.

Cláusula 7.2	Registros de Capacitación, Habilidades, Experiencia y Competencia	Se conservan los certificados de formación técnica del personal clave y los registros de asistencia a las charlas de concientización corporativa.
Cláusula 9.1	Resultados de Monitoreo y Medición del Desempeño	Se documentan informes de métricas (KPIs) sobre la eficacia de los controles (ej. porcentaje de sistemas parchados, tiempo medio de respuesta a incidentes).
Cláusula 9.2	Programa y Resultados de las Auditorías Internas	Planificación anual de auditorías, listas de verificación utilizadas y hallazgos detallados de no conformidades detectadas.
Cláusula 9.3	Actas de Revisión de la Alta Dirección	Minutas formales que demuestran la reunión de los directivos para revisar el desempeño del SGSI, asignación de presupuestos y estado de los riesgos.

Matriz 2: Lista de Verificación del SGSI (Preguntas Maestras - Cláusulas 4 a 10)

Esta sección abarca aproximadamente 153 preguntas derivadas de los requisitos certificables ("shall" o "debe") de la norma, diseñadas para evaluar el esqueleto directivo.[9] La tabla a continuación destila las consultas más críticas.

Área de Evaluación (Cláusula)	Pregunta Estratégica de Auditoría	Evidencia Operativa o Artefacto Esperado
Contexto de la Organización (4.1, 4.2)	¿Se han identificado y analizado exhaustivamente los problemas internos/externos y los requisitos legales, regulatorios y contractuales de las partes interesadas?	Matriz FODA/PESTLE orientada a seguridad; inventario actualizado de leyes de privacidad de datos aplicables y cláusulas de confidencialidad de clientes.[9]
Liderazgo (5.1, 5.3)	¿La alta dirección demuestra un liderazgo activo asegurando que el SGSI se integre en los procesos de negocio y asignando responsabilidades claras?	Presupuestos de ciberseguridad aprobados; descripciones de cargos (Job Descriptions) detallando responsabilidades de seguridad; comunicaciones ejecutivas.[4]

Planificación y Riesgo (6.1, 6.2)	¿Se ejecuta el proceso de evaluación de riesgos a intervalos planificados o cuando ocurren cambios significativos, generando resultados válidos y comparables?	Registros históricos del registro de riesgos (Risk Register); matrices térmicas de riesgo; planes de tratamiento firmados por los dueños de los riesgos.[11]
Soporte y Concientización (7.1 - 7.5)	¿Todo el personal sujeto al alcance del SGSI es consciente de su contribución a la eficacia de la seguridad y de las implicaciones de no cumplir con los requisitos?	Resultados estadísticos de simulacros de phishing; registros del proceso de inducción de nuevos empleados (onboarding); encuestas de cultura de seguridad.[9]
Operación (8.1 - 8.3)	¿Se implementan y controlan de manera efectiva y planificada los procesos operativos y el plan de tratamiento de riesgos?	Logs de sistemas; evidencia de ejecución de controles técnicos (dashboards); gestión documentada de los cambios tecnológicos.[9]
Evaluación del Desempeño (9.1 - 9.3)	¿Se evalúa continuamente el rendimiento de la seguridad y se informan los resultados a la alta dirección para garantizar que el programa sigue	Informes técnicos de monitoreo; registro documentado de los resultados de auditorías internas y minutas de las revisiones gerenciales con decisiones de

	siendo adecuado?	mejora.[13]
Mejora (10.1, 10.2)	¿Existe un proceso institucionalizado para reaccionar ante no conformidades e incidentes, investigar su causa raíz y evitar su recurrencia?	Registro de incidentes (Incident Log); informes forenses o de Análisis de Causa Raíz (RCA); verificación de implementación de acciones correctivas.[9]

Matriz 3: Lista de Verificación Táctica de Controles (Anexo A 2022)

Construida sobre la base de 93 preguntas específicas, esta lista evalúa la materialización empírica de las defensas teóricas descritas en la Declaración de Aplicabilidad.[9] El auditor busca constatar que los controles previenen vulnerabilidades y operan con eficacia en el entorno de producción.

Eje Temático	**Control Específico (Ref.)**	**Criterio de Auditoría: Verificación de Campo**	**Artefactos / Pruebas de Cumplimiento a Recolectar**
Organizacional	**Inteligencia de Amenazas (A.5.7)**	¿Se recopila, procesa y analiza continuamente información sobre amenazas relevantes para	Suscripciones a boletines de inteligencia (CERTs, fuentes OSINT); informes internos de

		adaptar proactivamente las estrategias de mitigación?	análisis de indicadores de compromiso (IoC); reglas actualizadas en firewalls.[4]
Organizacional	**Relaciones con Proveedores (A.5.19 - A.5.22)**	¿Se abordan e imponen sistemáticamente los requisitos de seguridad de la información en los acuerdos con proveedores de tecnología y cadena de suministro?	Contratos que incluyen cláusulas de cumplimiento (SLAs) de seguridad; cuestionarios de evaluación de riesgos a terceros completados; auditorías a proveedores.[12]
Organizacional	**Seguridad en la Nube (A.5.23)**	¿Se han definido, documentado e implementado las responsabilidades de seguridad para la adquisición, uso y gestión operativa de los servicios en la nube?	Matriz de responsabilidad compartida documentada; configuraciones seguras aplicadas en consolas de AWS/Azure; políticas de control de acceso a recursos de la nube.[4]

Personas	**Trabajo a Distancia (A.6.7)**	¿Se han implementado y comunicado medidas de seguridad para proteger la información accedida, procesada o almacenada en ubicaciones fuera del perímetro de la organización?	Política de teletrabajo firmada; evidencia de conexiones a través de VPN cifradas; autenticación multifactor (MFA) obligatoria; cifrado de disco duro en portátiles corporativas.[4]
Físico	**Perímetros de Seguridad (A.7.1) y Monitoreo (A.7.4)**	¿Las instalaciones de procesamiento de información sensible están protegidas por perímetros robustos y monitoreadas continuamente contra intrusiones físicas?	Inspección visual en sitio de controles de acceso (molinetes, sistemas biométricos, cerraduras electrónicas); registros y logs de visitantes; sistemas CCTV activos y revisados.[4]
Tecnológico	**Gestión de Vulnerabilidade**	¿Se recopila información sobre	Informes periódicos de

	s (A.8.8)	vulnerabilidades de los sistemas de información, evaluando su exposición y tomando medidas de mitigación de forma oportuna?	escaneo de vulnerabilidades; política formal de gestión de parches; evidencia de la instalación de actualizaciones críticas dentro de los plazos establecidos.[12]
Tecnológico	**Prevención Fuga Datos (DLP) (A.8.12)**	¿Se aplican medidas tecnológicas preventivas y detectivas para evitar la divulgación, extracción o pérdida no autorizada de información confidencial?	Soluciones de software DLP operativas en endpoints y redes; bloqueo preventivo de puertos USB; sistemas de alerta configurados para descargas y transferencias anómalas de datos.[4]
Tecnológico	**Monitoreo de Actividades (A.8.16)**	¿Se supervisan proactivamente las redes, los sistemas y las	Implementación y uso activo de sistemas SIEM (Security

		aplicaciones en busca de comportamientos anómalos o actividades maliciosas y se toman las medidas adecuadas?	Information and Event Management) o EDR; logs de detección de anomalías; procedimientos vinculados de respuesta a incidentes.[5]
Tecnológico	**Codificación Segura (A.8.28)**	¿Se establecen, aplican y revisan consistentemente principios de codificación segura en todos los ciclos de desarrollo de software in-house?	Directrices de desarrollo seguro documentadas (ej. OWASP); ejecución de pruebas SAST/DAST en entornos de integración continua (CI/CD); evidencia de revisión de código por pares.[5]

La Evolución hacia la Automatización del Cumplimiento (Automated Compliance)

Históricamente, la gestión de un programa ISO 27001 y la preparación rigurosa para una auditoría de certificación han dependido de procesos altamente manuales, fragmentados y crónicamente propensos al error. En las estructuras organizacionales

tradicionales, el cumplimiento implica a directores de seguridad o administradores de GRC (Governance, Risk, and Compliance) persiguiendo incesantemente a diversos departamentos para recopilar firmas, recolectando manualmente capturas de pantalla de configuraciones de servidores, rastreando activos en hojas de cálculo estáticas y consolidando evidencias en carpetas compartidas.[24] Esta metodología manual parece de bajo costo inicialmente, pero con el tiempo se vuelve exponencialmente onerosa debido al enorme volumen de trabajo humano, el estrés de la preparación reactiva para la auditoría y los costos de corregir errores estructurales de última hora.[24]

El riesgo subyacente más severo del cumplimiento manual no es la fatiga del equipo, sino la carencia de visibilidad en tiempo real.[24] Sin una visión holística de las operaciones, la alta dirección es incapaz de percibir si los controles se han debilitado, están vencidos o se aplican de manera inconsistente, creando profundos puntos ciegos que aumentan el riesgo regulatorio, operativo y reputacional.[24] Además, esto genera el pernicioso fenómeno de la "seguridad de auditoría", donde la organización maximiza sus defensas semanas antes de la inspección, permitiendo que la rigurosidad decaiga dramáticamente el resto del año, exponiéndose a incidentes reales.

En respuesta a estas deficiencias, el paradigma tecnológico ha pivotado drásticamente hacia el software de Automatización del Cumplimiento (Automated Compliance Management).[24] Plataformas integradas y especializadas—tales como Vanta, Drata y V-Comply—están redefiniendo el ciclo de vida del SGSI al conectar sus motores de reglas directamente a las infraestructuras de la organización a través de múltiples APIs.[25] Estos sistemas se integran nativamente con entornos en la nube (AWS, Azure, GCP), proveedores de identidad y accesos (Okta, Google Workspace, Azure AD), plataformas de recursos humanos y herramientas de desarrollo (GitHub, Jira).[27]

El núcleo de la automatización reside en el Monitoreo Continuo de Controles (Continuous Control Monitoring). En lugar de que un equipo humano verifique trimestralmente y de forma muestral si las computadoras portátiles están protegidas, la plataforma escanea en tiempo real el gestor de dispositivos móviles (MDM). Si

detecta que un empleado de reciente incorporación posee un equipo sin el cifrado de disco activado, el sistema levanta una alerta inmediata, crea un ticket de remediación automática y vincula la deficiencia instantáneamente a los controles correspondientes del Anexo A de ISO 27001.[24]

La automatización no solo consolida y centraliza la evidencia de manera continua para presentarla sin fricciones ante un auditor, acelerando drásticamente el proceso de certificación [25], sino que democratiza la seguridad al suplir la falta de conocimiento profundo in-house mediante guías integradas.[25] Herramientas emergentes en este sector incluso aplican Inteligencia Artificial (IA) para la validación de evidencias y la automatización de cuestionarios de seguridad de proveedores.[27] Sin embargo, la automatización también presenta limitaciones: las herramientas orientadas a un cumplimiento acelerado (speed-to-audit), ideales para startups tecnológicas, a menudo requieren la adquisición de módulos adicionales costosos a medida que los programas de gestión de riesgos maduran y se vuelven más sofisticados [27], y enfrentan severos obstáculos al intentar integrarse con sistemas heredados (legacy) on-premise que carecen de conectividad API moderna.

Ecosistema Regulatorio y Dinámicas de Adopción en la República Argentina

El análisis de la aplicabilidad, relevancia y metodologías de implementación de la norma ISO 27001 debe contextualizarse ineludiblemente dentro del marco regulatorio y comercial local de las entidades evaluadas. En la República Argentina, el estándar ha experimentado una adopción acelerada y expansiva, impulsada por dos vectores estratégicos convergentes: la presión regulatoria del sector financiero para asegurar la estabilidad sistémica, y los exigentes requerimientos contractuales de clientes internacionales para las empresas de base tecnológica.

El Impacto en el Sector Financiero: BCRA y la Comunicación "A" 7724

Para las instituciones bancarias, proveedores de servicios de pago y entidades financieras operativas en Argentina, la ciberseguridad ha dejado de ser una disciplina operativa y se ha posicionado como un pilar de la gestión de riesgo sistémico regulado por el Estado.[28] El Banco Central de la República Argentina (BCRA) ha endurecido sostenidamente sus exigencias mediante marcos normativos complejos, siendo la **Comunicación "A" 7724** un hito fundamental emitido en 2023.[28]

Esta regulación demanda a las entidades financieras la instrumentación de marcos robustos para la gestión de activos tecnológicos, la evaluación sistemática de vulnerabilidades, la implementación de planes probados de respuesta a incidentes y una gestión exhaustiva del riesgo asociado a terceras partes y proveedores de tecnología.[28] Al analizar comparativamente los requerimientos de la Comunicación "A" 7724, se hace evidente un mapeo directo y granular con la norma ISO 27001 y su Anexo A.[32] Un ejemplo manifiesto se encuentra en la sección 4.4.1 de la normativa del BCRA, que exige definir procedimientos para la clasificación de datos considerando la "participación del propietario del dato" y los criterios de "integridad, disponibilidad y confidencialidad".[30] Este requerimiento es un reflejo fáctico y exacto de los controles A.5.12 (Clasificación de la información) y A.5.13 (Etiquetado de la información) de ISO 27001.

La criticidad de alinear los esquemas de cumplimiento con estándares internacionales auditables se exacerbó radicalmente con la reciente promulgación del Decreto 353/2025, el cual instaura oficialmente el **Sistema de Finanzas Abiertas (Open Finance)** en Argentina.[31] Este modelo disruptivo autoriza y facilita, mediante consentimiento explícito, que las instituciones supervisadas por el BCRA compartan datos transaccionales de los individuos a través de Interfaces de Programación de Aplicaciones (APIs) con múltiples actores del ecosistema financiero y Fintech.[31] Esta arquitectura de interconectividad masiva expande dramáticamente la superficie de ataque del sector financiero argentino, introduciendo nuevas y profundas vulnerabilidades a través de flujos de datos extendidos y multiplicidad de interfaces.[31]

Ante esta topología de riesgo sistémico interconectado, donde la debilidad de un proveedor de pagos incipiente puede comprometer la red de un banco tradicional establecido, el BCRA ha reforzado (a través de regulaciones preexistentes como la Comunicación "A" 8280) la exigencia de adherir explícitamente a los estándares ISO 27001 para la gestión de incidentes y riesgos de terceros.[31] El estándar funciona así como el lenguaje unificador que asegura la homogeneidad en las posturas defensivas de todos los participantes del Open Finance.

Certificación Local y Dinámica Organizacional en PyMEs

En el entramado empresarial local, la verificación y emisión de certificados recae en entidades certificadoras de gran prestigio como IRAM (Instituto Argentino de Normalización y Certificación), SGS, PwC y G-CERTI.[32] Un aspecto estratégico relevante para las organizaciones exportadoras de servicios es que entidades de arraigo local como IRAM emiten certificaciones avaladas por IQNET.[34] Este reconocimiento internacional inmediato facilita a las empresas argentinas superar las rigurosas barreras de entrada comerciales al operar en mercados como el europeo o el norteamericano, donde la demostración de la protección de la información corporativa es un pre-requisito no negociable en las licitaciones corporativas y gubernamentales.[2]

Para las Pequeñas y Medianas Empresas (PyMEs) en Argentina, la implementación integral de un SGSI bajo la norma ISO 27001 representa un desafío técnico y financiero sustancial debido a las evidentes restricciones de recursos presupuestarios y la escasez de personal altamente especializado.[39] Sin embargo, la inherente flexibilidad y adaptabilidad del estándar —basado intrínsecamente en el riesgo— permite una escalabilidad proporcional.[12] Un análisis profundo revela que las PyMEs argentinas (especialmente aquellas orientadas al desarrollo de software SaaS, logística integrada, Fintechs y servicios profesionales) adoptan enfoques altamente pragmáticos.[12] En lugar de adquirir infraestructuras de ciberseguridad costosas y sobredimensionadas desde el día uno, confían inicialmente en la formalización de procesos internos, el fomento de la higiene cibernética básica, la concienciación

intensiva de sus empleados y el apalancamiento inteligente de los controles de seguridad nativos que ofrecen los proveedores de nube pública, logrando así establecer un SGSI eficiente, certificable y proporcionado a sus riesgos reales.[39] Este abordaje se refleja en casos de éxito del mercado argentino donde organizaciones de diversos sectores (como Abasto del Norte en Corrientes con tecnología blockchain, o empresas tecnológicas como OCP Tech y GPI Global Partner en Buenos Aires) demuestran que la cultura de cumplimiento, ya sea mediante ISO 9001, 14001, o la propia ISO 27001, permite estandarizar procesos complejos, asegurar la trazabilidad y operar de manera competitiva bajo esquemas de sistemas de gestión integrados internacionales.[32]

Análisis Comparativo Estratégico: ISO 27001, NIST CSF y SOC 2

En la fase de planificación de la estrategia de ciberseguridad corporativa y el aseguramiento del cumplimiento regulatorio (GRC), una inquietud recurrente de las mesas directivas radica en la selección del marco normativo óptimo, debatiéndose frecuentemente entre ISO 27001, el Cybersecurity Framework del NIST (NIST CSF) y las auditorías de Reportes SOC 2. Aunque a menudo se los menciona en el mercado corporativo como enfoques intercambiables, un análisis detallado revela diferencias fundamentales en su arquitectura conceptual, validación, madurez requerida y orientación comercial.[2]

Característica Estratégica Analizada	**ISO/IEC 27001:2022**	**NIST Cybersecurity Framework (CSF)**	**SOC 2 (System and Organization Controls 2)**

Naturaleza del Documento y Formato	Estándar Internacional diseñado como un conjunto de requisitos prescriptivos para la construcción formal de un Sistema de Gestión.[2]	Guía de mejores prácticas concebida como un manual de instrucciones voluntario para construir o perfeccionar programas de ciberseguridad.[2]	Reporte de auditoría de atestación (no es una certificación formal). Evalúa los controles internos frente a Criterios de Confianza definidos.[42]
Origen, Ámbito y Reconocimiento	Desarrollado y mantenido por la Organización Internacional de Normalización (ISO). Reconocimiento y exigencia de carácter eminentemente global.[2]	Desarrollado por una agencia gubernamental estadounidense (Instituto Nacional de Estándares y Tecnología). Alta adopción en el sector privado y público de EE.UU..[2]	Creado por el Instituto Americano de Contadores Públicos Certificados (AICPA). Es un estándar exigido de facto en el mercado SaaS corporativo de Norteamérica.[43]
Arquitectura Central y Principios Rectores	Se estructura fundamentalmente en torno al ciclo de vida de gestión de riesgos y la preservación de la Tríada CIA	Basado pragmáticamente en 5 funciones o pilares centrales de resiliencia operativa: Identificar,	Se fundamenta operativamente en la evaluación de 5 Criterios de Servicios de Confianza (TSC): Seguridad,

	(Confidencialidad, Integridad, Disponibilidad).[2]	Proteger, Detectar, Responder y Recuperar.[2]	Disponibilidad, Integridad del Procesamiento, Confidencialidad y Privacidad.[43]
Mecanismo de Validación y Auditoría	Implica una auditoría formal y rigurosa en dos fases realizada por un ente externo acreditado, culminando en un certificado público de cumplimiento.[2]	Se apoya en metodologías de autoevaluación (Self-assessment). No existe un mecanismo formal, ni un organismo oficial que emita un certificado de cumplimiento de NIST.[2]	Auditoría técnica y administrativa realizada exclusivamente por un Contador Público Autorizado (CPA) calificado. Emite un reporte confidencial y detallado.[42]
Madurez Organizacional Requerida	Recomendado para organizaciones con una madurez de riesgo intermedia a alta que necesitan formalizar y sistematizar exhaustivamente sus políticas a	Funciona como el modelo óptimo para organizaciones que se encuentran en las fases formativas o tempranas y necesitan estructurar una postura de	Fundamental para empresas proveedoras de tecnología (especialmente B2B SaaS) que necesitan demostrar la eficacia de sus controles de protección de

	largo plazo.[2]	seguridad básica e incremental.[2]	datos ante grandes clientes.[43]
Costos Inherentes a la Adopción	Requiere una inversión considerable que involucra herramientas tecnológicas, consultoría especializada, y tarifas de certificación recurrentes que pueden ascender significativamente.[2]	El marco en sí mismo es de acceso público y completamente gratuito. Al no requerir auditoría oficial, se eliminan los honorarios directos de certificación.[2]	El costo es variable y suele ser elevado, dependiendo de la firma auditora y la cantidad de Criterios de Servicios de Confianza evaluados durante el periodo de auditoría (Tipo I o Tipo II).

Un análisis de las interacciones e intersecciones lógicas entre estos marcos evidencia que no son mutuamente excluyentes, sino sinérgicos y complementarios. La adopción e implementación inicial de las directrices estructurales del NIST CSF permite a una organización cubrir exitosamente aproximadamente el 80% de los requisitos prácticos necesarios para lograr la conformidad con el estándar ISO 27001.[2] El NIST CSF sobresale indiscutiblemente por su granularidad táctica al detallar cómo responder operativamente a un incidente de seguridad y cómo orquestar la recuperación rápida de los sistemas afectados (a través de las funciones de Responder y Recuperar).[2] En contrapartida, la norma ISO 27001 proporciona una arquitectura de gobernanza corporativa muy superior, asegurando que los controles tácticos no existan en un vacío técnico, sino que estén profundamente integrados en el tejido administrativo, directivo y operativo de la empresa de forma ininterrumpida a través de la aplicación sistemática del ciclo Planificar-Hacer-Verificar-Actuar

(PDCA).[2]

Conclusiones Estratégicas y Recomendaciones Operativas

La norma ISO/IEC 27001:2022 ha superado su conceptualización como un simple requerimiento técnico para erigirse como un habilitador estratégico de negocios de alcance global, evidenciando de manera irrefutable la diligencia debida corporativa en un entorno digital inherentemente hostil, volátil y regulado. El escrutinio exhaustivo de sus fundamentos, la reestructuración de sus controles defensivos y las dinámicas metodológicas de implementación arrojan las siguientes implicancias analíticas fundamentales para el liderazgo corporativo:

1. **La Gobernanza Dirige a la Tecnología:** Los proyectos de certificación ISO 27001 fracasan sistemática y previsiblemente cuando son percibidos, presupuestados y liderados como iniciativas exclusivas del departamento de TI.[4] El diseño fundacional de la norma y sus exigentes cláusulas obligatorias requieren que la alta dirección empresarial asuma la propiedad del proceso, establezca el tono cultural de la seguridad, financie la evaluación de los riesgos sistémicos y asuma la responsabilidad final y documentada sobre la Declaración de Aplicabilidad (SoA).
2. **La Dinámica Evolutiva de las Listas de Verificación (Checklists):** El uso de listas de verificación no debe degradarse a un simple ejercicio burocrático de marcado de casillas (tick-box exercise). Como se evidencia en las estructuras maestras de auditoría sugeridas, estas matrices deben actuar como instrumentos analíticos que orienten a los auditores hacia la búsqueda de evidencias empíricas de eficacia operativa, apartando a las empresas de la peligrosa falacia de la "seguridad de escritorio".[6]
3. **El Imperativo de la Automatización del Cumplimiento:** A mediano y largo plazo, el sostenimiento de un programa de cumplimiento mediante procesos

manuales fragmentados es ineficiente y financieramente insostenible. La adopción estratégica de plataformas GRC que permiten un monitoreo continuo de controles (Continuous Control Monitoring) no solo reduce significativamente los tiempos muertos y los costos asociados a las auditorías, sino que otorga a la alta dirección una visibilidad ininterrumpida sobre la postura de riesgo organizativa, mitigando fallos silenciosos en las defensas.[24]

4. **Convergencia Normativa Regional (Caso Argentina):** En ecosistemas regulatorios altamente dinámicos como la República Argentina, las disposiciones del Banco Central (Comunicación "A" 7724) y la habilitación estructural del Sistema de Finanzas Abiertas (Open Finance, Decreto 353/2025) transforman los postulados del estándar ISO 27001 de mejores prácticas voluntarias a mandatos cuasi-obligatorios de protección. El incumplimiento de estos preceptos expone a las entidades financieras y proveedores tecnológicos no solo a sanciones regulatorias, sino a la generación de disrupciones de riesgo sistémico de alcance nacional.[28]
5. **Principio de Proporcionalidad del Riesgo:** El éxito perdurable de un SGSI reside en comprender el núcleo de su diseño: la proporcionalidad. Las metodologías formales de evaluación de riesgos dotan a la organización de la autoridad argumentativa para evitar inversiones desproporcionadas en amenazas marginales. La selección justificada de los controles del Anexo A permite construir defensas asimétricas que se adaptan estrictamente a las realidades presupuestarias, garantizando que el sistema proteja a la empresa sin asfixiar la agilidad comercial ni la innovación operativa requerida en la economía digital.[7]

Obras citadas

1. ISO 27001 Controls: Overview of all measures from Annex A - DataGuard, fecha de acceso: abril 8, 2026, https://www.dataguard.com/iso-27001/annex-a/
2. NIST CSF vs. ISO 27001: What's the difference? | Vanta, fecha de acceso: abril 8, 2026, https://www.vanta.com/collection/iso-27001/nist-

csf-vs-iso-27001

3. ISO 27001:2022 Annex A Explained & Simplified - ISMS.online, fecha de acceso: abril 8, 2026, https://www.isms.online/iso-27001/annex-a-2022/
4. ISO 27001:2022 Annex A Controls | Complete Reference List, fecha de acceso: abril 8, 2026, https://hightable.io/iso-27001-annex-a-controls-reference-guide/
5. ISO 27001:2013 vs ISO 27001:2022 | CSA - Cloud Security Alliance, fecha de acceso: abril 8, 2026, https://cloudsecurityalliance.org/articles/what-s-the-difference-between-iso-27001-2013-and-iso-27001-2022
6. ISO 27001 Checklist (Free PDF & XLS Downloads) | Pivot Point, fecha de acceso: abril 8, 2026, https://www.pivotpointsecurity.com/iso-27001-checklist/
7. ISO 27001 Implementation Checklist (Free PDF Download) | UpGuard, fecha de acceso: abril 8, 2026, https://www.upguard.com/blog/iso-27001-implementation-checklist
8. Gap analysis versus risk assessment, fecha de acceso: abril 8, 2026, https://www.dewr.gov.au/download/13644/gap-analysis-versus-risk-assessment/27360/document/pdf
9. ISO 27001:2022 Internal Audit Checklist Template | ISMS Excel ..., fecha de acceso: abril 8, 2026, https://www.iso-9001-checklist.co.uk/iso-27001/internal-audit-checklist-template.htm
10. ISO 27001 Mandatory Documents: The Complete 2025 Checklist ..., fecha de acceso: abril 8, 2026, https://sprinto.com/blog/iso-27001-mandatory-documents/
11. ISO 27001 Checklist: Your Comprehensive Guide to Easy ..., fecha de

acceso: abril 8, 2026, https://www.dataguard.com/blog/iso-27001-checklist-a-16-step-comprehensive-guide

12. Guia de implementacion ISO 27001 paso a paso | G-CERTI Argentina, fecha de acceso: abril 8, 2026, https://gcerti.com.ar/recursos/guia-iso-27001-implementacion
13. ISO 27001 compliance checklist | Vanta, fecha de acceso: abril 8, 2026, https://www.vanta.com/collection/iso-27001/iso-27001-compliance-checklist
14. ISO 27001:2022 Audit Checklist Template | ISMS.online, fecha de acceso: abril 8, 2026, https://www.isms.online/iso-27001/audits/audit-checklist-template/
15. (PDF) ISO 27001 IN BANKING: AN EVALUATION OF ITS IMPLEMENTATION AND EFFECTIVENESS IN ENHANCING INFORMATION SECURITY - ResearchGate, fecha de acceso: abril 8, 2026, https://www.researchgate.net/publication/377420098_ISO_27001_IN_BANKING_AN_EVALUATION_OF_ITS_IMPLEMENTATION_AND_EFFECTIVENESS_IN_ENHANCING_INFORMATION_SECURITY
16. 4 Ways A Gap Assessment Template Can Help Reduce Your Business Risk, fecha de acceso: abril 8, 2026, https://www.pivotpointsecurity.com/gap-assessment-template/
17. ISO 27001 Programme starts with Gap Analysis or Risk Assessment? | URM Consulting, fecha de acceso: abril 8, 2026, https://www.urmconsulting.com/blog/should-you-start-your-iso-27001-programme-with-a-gap-analysis-or-a-risk-assessment
18. Free ISO 27001 Gap and Maturity Assessment templates : r/cybersecurity - Reddit, fecha de acceso: abril 8, 2026, https://www.reddit.com/r/cybersecurity/comments/1k91491/free_iso_27001_gap_and_maturity_assessment/

19. ISO 27001 Implementation Checklist Guide | PDF | Risk | Regulatory Compliance - Scribd, fecha de acceso: abril 8, 2026, https://www.scribd.com/document/904369076/ISO-27001-Implementation-Guide-Checklist-of-Steps-Timing-And-Costs-Involved-pdf
20. ISO 27001 Compliance Checklist - Device42, fecha de acceso: abril 8, 2026, https://www.device42.com/compliance-standards/iso-27001-compliance-checklist/
21. Comprehensive Checklist for Achieving ISO 27001:2022 Certification - ISMS.online, fecha de acceso: abril 8, 2026, https://www.isms.online/iso-27001/checklist/
22. ISO/IEC 27001: 2022 Information Security Management System Toolkits, fecha de acceso: abril 8, 2026, https://it-toolkits.org/it_ISO27001-Toolkits.html
23. Download ISO 27001 Checklist (xls) - High Table, fecha de acceso: abril 8, 2026, https://hightable.io/wp-content/uploads/2022/12/01-ISO-27001-Implementation-Checklist.xlsx
24. Manual vs Automated Compliance Management: Cost & Risk - V-Comply, fecha de acceso: abril 8, 2026, https://www.v-comply.com/blog/manual-automated-compliance-management/
25. Automated ISO 27001 vs. manual ISO 27001 | Vanta, fecha de acceso: abril 8, 2026, https://www.vanta.com/collection/iso-27001/automated-iso-27001-vs-manual-iso-27001
26. Manual vs Automated Compliance: Which Is Right for Your Business? - Uproot Security, fecha de acceso: abril 8, 2026, https://www.uprootsecurity.com/blog/manual-vs-automated-compliance

27. 7 Best Compliance Automation Software Options in 2026 - Drata, fecha de acceso: abril 8, 2026, https://drata.com/learn/compare/best-compliance-automation-software
28. Comunicación "A" 7724 del BCRA: ¿Cómo aplicarla para garantizar la seguridad de los bancos en Argentina? - ZMA IT Solutions, fecha de acceso: abril 8, 2026, https://zma.la/comunicaciona-7724/
29. Communication A7724 from the Central Bank of the Argentine Republic, fecha de acceso: abril 8, 2026, https://www.grantthornton.com.ar/en/insights/articles/2023/communication-a7724-bcra/
30. COMUNICACIÓN "A" 7724 10/03/2023 A LAS ENTIDADES ... - BCRA, fecha de acceso: abril 8, 2026, https://www.bcra.gob.ar/archivos/Pdfs/comytexord/A7724.pdf
31. Argentina FinTech Regulation 2025 - Beaumont Capital Markets, fecha de acceso: abril 8, 2026, https://beaumont-capitalmarkets.co.uk/featured_item/argentina-fintech-regulatory-developments-2025/
32. Casos de Éxito — Empresas Certificadas | G-CERTI Argentina, fecha de acceso: abril 8, 2026, https://gcerti.com.ar/casos-de-exito
33. ISO 27001 for the Banking Sector | ISMS.online, fecha de acceso: abril 8, 2026, https://www.isms.online/sectors/iso-27001-for-the-banking-sector/
34. IRAM-ISO/IEC 27001 Certificá Seguridad de la Información | IRAM, fecha de acceso: abril 8, 2026, https://www.iram.org.ar/servicio/sistemas-de-gestion-de-la-seguridad-de-la-informacion/
35. Certificación ISO/IEC 27001: seguridad de la información, ciberseguridad y protección de la privacidad | SGS Argentina, fecha de acceso: abril 8,

2026, https://www.sgs.com/es-ar/services/certificacion-iso-iec-27001-seguridad-de-la-informacion-ciberseguridad-y-proteccion-de-la-privacidad

36. Certificaciones ISO - PwC Argentina, fecha de acceso: abril 8, 2026, https://www.pwc.com.ar/es/servicios/consultoria/regulaciones-riesgos-seguridad-fraude/forensic-services-pwc/certificacion-iso.html
37. Caso de Éxito: Mejores Prácticas aplicadas a la industria Metalúrgica - QM, fecha de acceso: abril 8, 2026, https://qmamericas.com/caso-de-exito-mejores-practicas-industria-metalurgica
38. Manual vs Automated Compliance: A Realistic Comparison | Matproof Blog, fecha de acceso: abril 8, 2026, https://matproof.com/blog/manual-vs-automated-compliance
39. ISO 27001 PARA PYMES - Re-Unir, fecha de acceso: abril 8, 2026, https://reunir.unir.net/bitstream/handle/123456789/3128/AngelaMaria_Parra_Giraldo.pdf?sequence=1&isAllowed=y
40. Normas ISO en Pymes: ¿Cuándo y Cómo implementarlas? - Crentio, fecha de acceso: abril 8, 2026, https://www.crentio.com/es-ar/blog/normas-iso-pyme
41. Casos de Éxito | Optimización de Costos y Seguridad en la Nube - Alianza Digital, fecha de acceso: abril 8, 2026, https://alianzadigital.com.ar/casos-de-exito/
42. ISO 27001 Vs. SOC 2 & NIST: A Framework Comparison | Xantrion, fecha de acceso: abril 8, 2026, https://www.xantrion.com/article/iso-27001-vs-soc-2-nist-a-framework-comparison
43. ISO 27001 vs SOC 2 vs NIST CSF: Guía Definitiva de Ciberseguridad 2026 | Blog G-Certi, fecha de acceso: abril 8, 2026, https://gcerti.org/blog/iso-27001-vs-soc2-vs-nist

44. ISO 27001 vs. NIST Cybersecurity Framework | Blog - OneTrust, fecha de acceso: abril 8, 2026, https://www.onetrust.com/blog/iso-27001-vs-nist-cybersecurity-framework/